

WEB APPLICATION SECURITY

Introduction

Web application security is also known as *WebAppSec*. It is the practice of protecting websites, applications and Ips from attacks. Web applications can be used without installation where a standard web browser is available such as *Chrome* and *Firefox*. The module also brought out the idea of web application as a program running on a remote server, where a server is a computer system running continuously to 'serve' the clients. The module will also cover web application security risks. Some of the risks covered include; Identification and Authentication Failure, Broken Access Control, Injection and Cryptographic failures. Finally the module will provide a practical example of web application security.

Objective.

- To understand what web application is.
- To understand the web application security risks.
- To understand the practical bit of web security.

Methodology

Level 1

This level covered the introductory part. Covered the standard web browsers such as; *Firefox*, *safari*, and *Chrome*. This web browsers are important since it is not necessary to install every program one need, instead one only needs to browse the related page. In this level, web application was brought out as a program running on a remote server, where a server is a computer system running continuously to serve clients.

Therefore, what you need to access a web application is a browser.

Answer the questions below

What do you need to access a web application?

Browser

✓ Correct Answer

Level 2

The level covered web application security risks. Covered the a few main categories common attacks against web applications, and would be evidence by considering the steps and attacks in the figure below.

- Log in at the website: The attacker can try to discover the password by trying many words. The attacker would use a long list of passwords with an automated tool to test them against the login page.
- Search for the product: The attacker can attempt to breach the system by adding specific characters and codes to the search term. The attacker's objective is for the target system to return data it should not or execute a program it should not.
- Provide payment details: The attacker would check if the payment details are sent in cleartext or using weak encryption. Encryption refers to making the data unreadable without knowing the secret key or password.

Also covered some of the OWASP top ten vulnerabilities. They include;

- **Identification and Authentication Failure**

Identification is the ability to identify a user uniquely. While authentication is the ability to prove a user is whom they claim to be.

The following is a good example of identification and authentication of different users.

Username	Password
Anne	freedom1
Beth	ZhiTQEA4
Christine	batman2020

- **Broken access control**

Access control ensures that each user can only access files to their role of work. The following is an example of the vulnerability.

- Failing to apply *the principle of the least privilege* and giving users more access permissions than they need. For example, an online customer should be able to view the prices of the items, but they should not be able to change them.
- Being able to view or modify someone else's account by using its unique identifier. For example, you don't want one bank client to be able to view the transactions of another client.
- Being able to browse pages that require authentication (logging in) as an unauthenticated user. For example, we cannot let anyone view the webmail before logging in.

- **Injection**

The module discussed it as a vulnerability in the web application where the user can insert malicious code as part of their input.

- **Cryptographic Failures**

The vulnerability refers to the failure in the process of encryption and decryption of data. Encryption is important as it ensures no one can read the data knowing the secret key. The following is the example of cryptographic failure.

- Sending sensitive data in clear text, for example, using `HTTP` instead of `HTTPS`. `HTTP` is the protocol used to access the web, while `HTTPS` is the secure version of `HTTP`. Others can read everything you send over `HTTP`, but not `HTTPS`.
- Relying on a weak cryptographic algorithm. One old cryptographic algorithm is to shift each letter by one. For instance, "TRY HACK ME" becomes "USZ IBDL NF." This cryptographic algorithm is trivial to break.
- Using default or weak keys for cryptographic functions. It won't be challenging to break the encryption that used `1234` as the secret key.

The tested my understanding by giving the following queries.

You discovered that the login page allows an unlimited number of login attempts without trying to slow down the user or lock the account. What is the category of this security risk?

Identification and Authentication Failure

✓ Correct Answer

You noticed that the username and password are sent in cleartext without encryption. What is the category of this security risk?

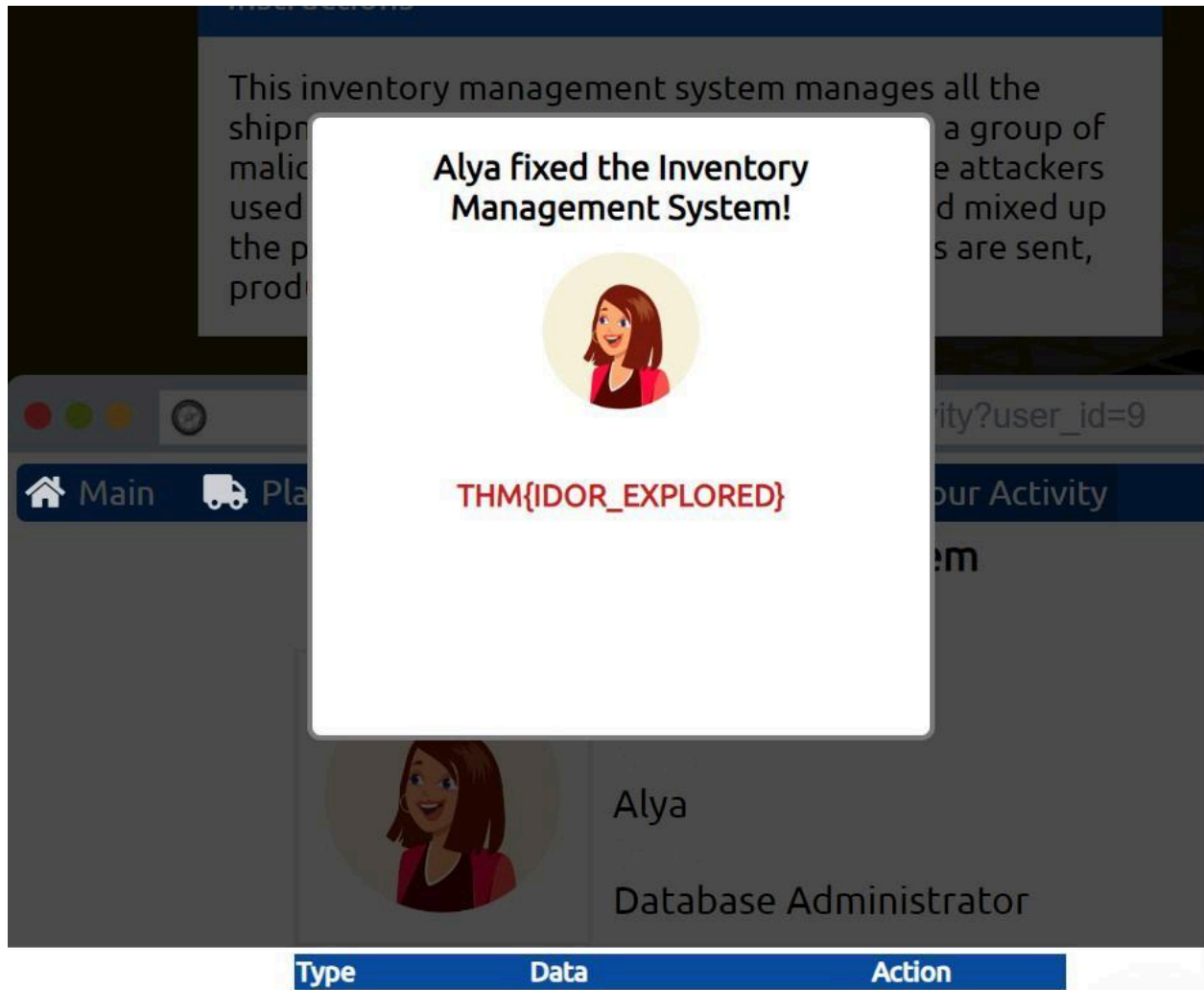
Cryptographic Failures

✓ Correct Answer

Level 3

The level covered an investigation on a vulnerable website that uses ***Insecure Direct Object Reference*** (IDOR), which falls under the category of Broken Access Control. Here an attacker can access information or perform actions not intended for them.

Hacked the system back to undo the attacker's steps. Also discovered which user account was used to make the malicious changes.



Check the other users to discover which user account was used to make the malicious changes and revert them. After reverting the changes, what is the flag that you have received?

THM{IDOR_EXPLORED}

✓ Correct Answer

💡 Hint

Conclusion

This module begun by providing a detailed introduction about web application security, the practice of protecting websites, applications and Ips from web attack. We actually don't need to install programs that one needs. Instead, the module covered the user of browsers to run the programs we need with ease and with no installations.

Some web security risks were also discussed. These security risks included identification and authorization failure, injection, broken access control, and cryptographic failures.

The module finally introduced us to an investigative practical session, to investigate a vulnerable website that uses **IDOR**.



Congratulations!

You've completed the room! Share this with your friends:



Twitter



Facebook



LinkedIn

[Leave feedback](#)